


[_ \(http://hl7.org/fhir/R4/searchform.html\)](http://hl7.org/fhir/R4/searchform.html)

[Security and Privacy \(secpriv-module.html\)](#) > **Security**

This page is part of the FHIR Specification (v4.0.1: R4 - Mixed Normative (<https://confluence.hl7.org/display/HL7/HL7+Balloting>) and STU (<https://confluence.hl7.org/display/HL7/HL7+Balloting>)) in it's permanent home (it will always be available at this URL). The current version which supercedes this version is 5.0.0 (<http://hl7.org/fhir/index.html>). For a full list of available versions, see the Directory of published versions [⚡](http://hl7.org/fhir/directory.html) (<http://hl7.org/fhir/directory.html>). Page versions: R5 (<http://hl7.org/fhir/R5/security.html>), R4B (<http://hl7.org/fhir/R4B/security.html>), **R4** R3 (<http://hl7.org/fhir/STU3/security.html>), R2 (<http://hl7.org/fhir/DSTU2/security.html>).

6.1.0_FHIR Security

FHIR Infrastructure ⚡ _ (http://www.hl7.org/Special/committees/fiwig/index.cfm) Work Group	Maturity Level _ (versions.html#maturity): 4	Standards Status _ (versions.html#std-process): <u>Trial Use</u> (versions.html#std-process)
---	--	---

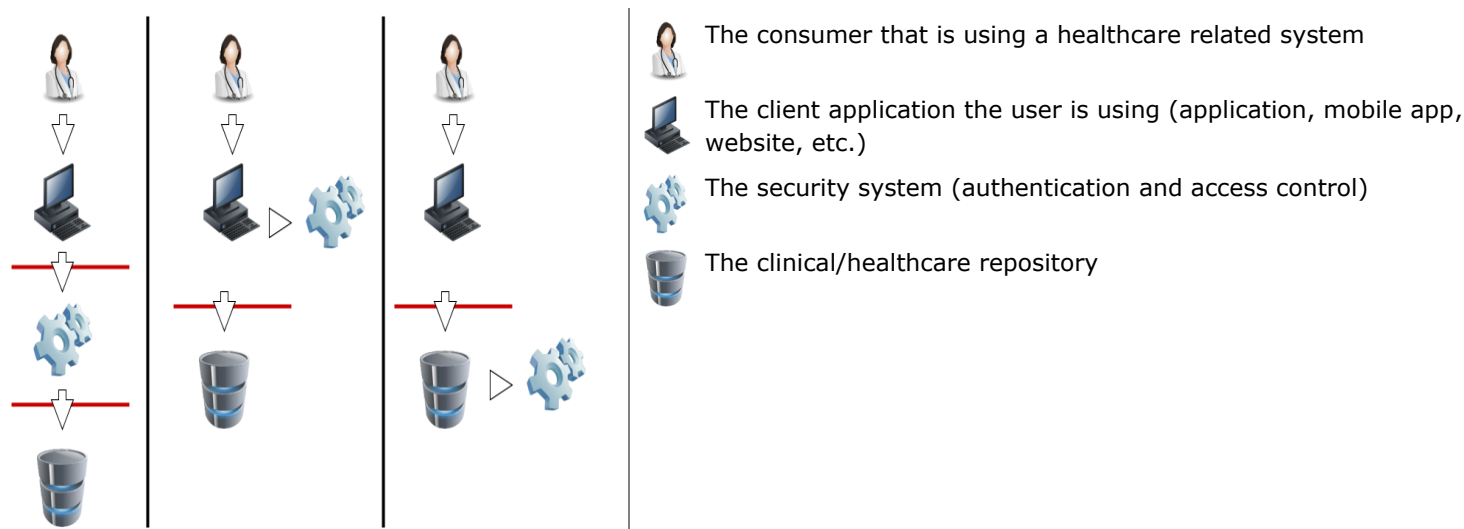
Fast Healthcare Interoperability Resources (FHIR) is not a security protocol, nor does it define any security related functionality. However, FHIR does define exchange protocols and content models that need to be used with various security protocols defined elsewhere. This section gathers all information about security in one section. A summary:

1. Time Keeping - all clocks should be synchronized using NTP/SNTP, and the design of the system should be robust against a system clock with the wrong value
2. Communications Security - all exchange of production data should be secured using TLS (e.g., https).
3. Authentication - Users/Clients must be authenticated. For web-centric, OAuth is recommended. When using OAuth, a profile of OAuth will be needed. Consider use of Smart-On-FHIR [⚡](http://docs.smarthealthit.org/) (<http://docs.smarthealthit.org/>) where appropriate.
4. Authorization/Access Control - FHIR defines a Security Label infrastructure to support access control management. FHIR may also define a set of resources to administer access control management, but does not define any at present
5. Audit - FHIR defines provenance ([provenance.html](#)) and audit event ([auditevent.html](#)) resources suitable for tracking the origins, authorship, history, status, and access of resources
6. Digital Signatures ([signatures.html](#)) - FHIR includes several specifically reserved locations for digital signatures
7. Attachments - FHIR allows for binary resources and attachments. These have their own concerns
8. Labels ([security-labels.html](#)) - FHIR allows for set of security related tags that affect the way resources are handled
9. Data Management Policies - FHIR defines a set of capabilities to support data exchange. Not all the capabilities that FHIR enables may be appropriate or legal for use in some combinations of context and jurisdiction (e.g. HIPAA, GDPR). It is the responsibility of implementers to ensure that relevant regulations and other requirements are met
10. Narrative - Care must be taken when displaying the narrative from FHIR resources
11. Input Validation - Validate all input received from other actors to assure the data is well formed and does not contain content that would cause unwanted system behaviour. Testing ensures that the input is not susceptible to data input validation errors by using techniques such as fuzzing, invalid input attacks, and injection attacks.

Time critical concerns regarding security flaws in the FHIR specification should be addressed to the FHIR email list [⚡](https://confluence.hl7.org/display/FHIR/Mailing+List+Instructions) (<https://confluence.hl7.org/display/FHIR/Mailing+List+Instructions>) for prompt consideration.

6.1.0.1 General Considerations

A production FHIR system will need some kind of security sub-system that administers users, user authentication, and user authorization. Where this subsystem fits into the deployment architecture is a matter for system design:



In this diagram, the red lines represent FHIR interfaces. From the perspective of the FHIR API, the client (consumer of FHIR services) may either interact with a security system that manifests as a FHIR server, and which depends on a subsequent FHIR interface to provide the actual storage, or either the client or server interacts with the security system independently. In each of these 3 scenarios, the different components may be assembled into applications or network components differently, but the same logical layout applies. The FHIR specification assumes that a security system exists, and that it may be deployed in front of or behind the FHIR API.

The security system includes the following subsystems:

- Authentication: identifies and authenticates the user
- Access Control decision engine: decides whether FHIR operations are allowed
- Audit Log: records actions to allow for subsequent review and detection of intrusion or inappropriate usage

Because there are a plethora of standards relating to the administration and functionality of the security system, FHIR does not provide user, profile, or other such administration resources. Instead, the FHIR resources are the targets of the policies expressed in these other approaches. What FHIR does specify is a way to apply [security labels \(security-labels.html\)](#) to resources so that a security system may use these (along with the contents of the resources if appropriate) to determine whether a user is authorized to perform a particular FHIR operation or not.

6.1.0.2 Security and Privacy Considerations

The appropriate protections for Privacy and Security are specific to the risks to Privacy and the risks to Security of that data being protected. This concept of appropriate protections is a very specific thing to the actual data. Any declaration of 'required' or 'optional' requirements that could be mentioned here are only recommendations for that kind of Resource in general for the most common use of that Resource. Where one uses the Resource in a way that is different than this most common use, one will have different risks and thus need different protections.

Most Resources will need some form of Access Control to Create, Update, or Delete. The following general guidance is given only as general guidance for READ and QUERY access:

6.1.0.2.1 Anonymous READ Access Resources

These resources tend to not contain any individual data, or business sensitive data. Most often these Resources will be available for anonymous access, meaning there is no access control based on the user or system requesting. However, these Resources do tend to contain important information that must be authenticated back to the source publishing them, and

protected from integrity failures in communication. For this reason, server authenticated https (TLS) is recommended to provide authentication of the server and integrity protection in transit. This is normal web-server use of [https](#).

6.1.0.2.2 Business Sensitive Resources

These Resources tend to not contain any individual data, but do have data that describe business or service sensitive data. The use of the term Business is not intended to only mean an incorporated business, but rather the broader concept of an organization, location, or other group that is not identifiable as individuals. Often these resources will require some sort of client authentication to assure that only authorized access is given. The client access control may be to individuals, or may be to system identity. For this purpose, possible client authentication methods such as: mutual-authenticated-TLS, APIKey, App signed JWT, or App OAuth client-id JWT For example: an App that uses a Business protected Provider Directory to determine other business endpoint details.

6.1.0.2.3 Individual Sensitive

These Resources do NOT contain Patient data, but do contain individual information about other participants. These other individuals are Practitioners, PractionerRole, CareTeam, or other users. These identities are needed to enable the practice of healthcare. These identities are identities under general privacy regulations, and thus must consider Privacy risk. Often access to these other identities are covered by business relationships. For this purpose, access to these Resources will tend to be Role specific using methods such as RBAC or ABAC.

6.1.0.2.4 Patient Sensitive

These Resources make up the bulk of FHIR and therefore are the most commonly understood. These Resources contain highly sensitive health information, or are closely linked to highly sensitive health information. These Resources will often use the [security labels \(security-labels.html\)](#) to differentiate various confidentiality levels within this broad group of Patient Sensitive data. Access to these Resources often requires a declared Purpose Of Use. Access to these Resources is often controlled by a [Privacy Consent \(consent.html\)](#). See the section below on [Authorization and Access Control](#).

6.1.0.2.5 Not classified

Some Resources can be used for a wide scope of use-cases that span very sensitive to very non-sensitive. These Resources do not fall into any of the above classifications, as their sensitivity is highly variable. These Resources will need special handling. These Resources often contain metadata that describes the content in a way that can be used for Access Control decisions.

6.1.0.3 Communications

For the [RESTful API \(http.html\)](#), normal HTTP security rules apply. Please follow the [HTTP specification Security Considerations section 9](#) <https://tools.ietf.org/html/rfc7231#section-9>). The [Service Base URL \(http.html#root\)](#) will specify whether TLS is required. Client authentication may be required by the server, possibly including the requirement for client certificates. When returning responses to non-authorized clients, ensure that Hypertext Transfer Protocol (HTTP) headers of a web server and API error messages or faults do not disclose detailed information about the underlying web server that could be the source of potential exploitation.

Please follow IETF Best Current Practice ([BCP 195](#) <https://tools.ietf.org/html/bcp195>)) - "[Recommendations for Secure Use of Transport Layer Security \(TLS\) and Datagram Layer Security \(DTLS\)](#)" <https://tools.ietf.org/html/bcp195>). This recommends TLS 1.2 or higher be used for all production data exchange, limits support for lower versions of TLS, and forbids SSL. Versions of TLS prior to TLS 1.2 should be used only where TLS 1.2 or higher is not available between partners. When using TLS, use with strong cipher suites (e.g. AES).

Consider using additional methods of security for an API to help authenticate where Domain Name System (DNS) responses are coming from and ensure that they are valid. For example, the use of Domain Name System Security Extensions (DNSSEC), a suite of extensions that add security to the DNS protocol, can ensure that domains associated with API endpoints that transmit health information or information required for API access are secure. DNSSEC provides origin authority, data integrity, and authenticated denial of existence. With DNSSEC, the DNS protocol is much less susceptible to certain types of attacks, particularly DNS spoofing attacks.

The TLS communications are established prior to any HTTP command/response, so the whole FHIR interaction is protected by the TLS communications. The security of the endpoints of the TLS communications must be risk-managed, so as to prevent inappropriate risks (e.g. audit logging of the GET parameters into an unprotected audit log).

When it is desirable to support browser-based javascript client applications, servers SHOULD consider enabling cross-origin resource sharing (CORS) [\(https://www.w3.org/TR/cors/\)](https://www.w3.org/TR/cors/) for the REST operations ([http.html](http://html.spec.whatwg.org/multipage/semantics.html#rest-operations)). Consider advice from sources including Enable-CORS [\(http://enable-cors.org/\)](http://enable-cors.org/) and Moesif blog on Guide to CORS Pitfalls [\(https://www.moesif.com/blog/technical/cors/Authoritative-Guide-to-CORS-Cross-Origin-Resource-Sharing-for-REST-APIs/\)](https://www.moesif.com/blog/technical/cors/Authoritative-Guide-to-CORS-Cross-Origin-Resource-Sharing-for-REST-APIs/). Experience shows that this is an area where ongoing issues may be expected as security holes are found and closed on an ongoing basis.

6.1.0.4 Authentication

Other than testing systems, FHIR servers should authenticate the clients. The server may choose to authenticate the client system and trust it, or to authenticate the individual user by a variety of techniques. For web-centric environments it is recommended to use OpenID Connect [\(http://openid.net/connect/\)](http://openid.net/connect/) (or other suitable authentication protocol) to verify identity of the end user, where it is necessary that end-users be identified to the application. It is recommended that OAuth [\(http://oauth.net/\)](http://oauth.net/) be used to authenticate and/or authorize the client and user. The Smart-On-FHIR [\(http://docs.smarthealthit.org/\)](http://docs.smarthealthit.org/) profile on OAuth is a recommended method for using OAuth.

The HEART Working Group [\(https://openid.net/wg/heart/\)](https://openid.net/wg/heart/) has developed a set of privacy and security specifications that enable an individual to control the authorization of access to RESTful health-related data sharing APIs, and to facilitate the development of interoperable implementations of these specifications by others. IHE IUA Profile [\(http://wiki.ihe.net/index.php/Internet_User_Authorization\)](http://wiki.ihe.net/index.php/Internet_User_Authorization) constrains OAuth token attributes to support Healthcare.

All systems shall protect authenticator mechanisms, and select the type of credential/strength of authenticator based on use-case and risk management.

6.1.0.5 Authorization/Access Control

Correctly identifying people, devices, locations and organizations is one of the foundations that any security system is built on. Most applications of security protocols, whether authentication, access control, digital signatures, etc. rely on the correct mapping between the relevant resources and the underlying systems. Note that this isn't necessary. There is nothing in FHIR that requires or relies on any security being in place, or any particular security implementation. However, real world usage will generally require this.

A holder of data should not allow the data to be communicated unless there are enough assurances that the other party is authorized to receive it. This is true for a client creating a resource through a PUT/POST, as much as it is true for a server returning resources on a GET. The presumption is that without proper authorization, to the satisfaction of the data holder, the data does not get communicated.

Two of the classic Access Control models are: Role-Based Access Control (RBAC), and Attribute-Based Access Control (ABAC).

In Role-Based Access Control (RBAC), permissions are operations on an object that a user wishes to access. Permissions are grouped into roles. A role characterizes the functions a user can perform. Roles are assigned to users. If the user's role has the appropriate permissions to access an object, then that user is granted access to the object. FHIR readily enables RBAC, as FHIR Resources are object types and the CRUDE (Create, Read, Update, Delete, Execute) events (the FHIR equivalent to permissions in the RBAC scheme) are operations on those objects.

In Attribute-Based Access Control (ABAC), a user requests to perform operations on objects. That user's access request is granted or denied based on a set of access control policies that are specified in terms of attributes and conditions. FHIR readily enables ABAC, as instances of a Resource in FHIR (again, Resources are object types) can have attributes associated with them. These attributes include security tags, environment conditions, and a host of user and object characteristics, which are the same attributes as those used in ABAC. Attributes help define the access control policies that determine the operations a user may perform on a Resource (in FHIR) or object (in ABAC). For example, a tag (or attribute) may specify that the identified Resource (object) is not to be further disclosed without explicit consent from the patient.

The rules behind the access control decision are often very complex, and potentially depend on information sourced from:

- Client, such as user identity, user role, location, level of assurance
- Resource, such as confidentiality, sensitivity, type of data, date ranges covered by the data, author of the data
- Patient, such as the patient identity, patient relationship to the user, patient consent policies

- Context of the transaction, system identity, time-of-day, purpose of use, workflow state, and transport security

For one source of further information, see the [IHE Access Control white paper](http://www.ihe.net/Technical_Framework/upload/IHE_ITI_TF_WhitePaper_AccessControl_2009-09-28.pdf) (http://www.ihe.net/Technical_Framework/upload/IHE_ITI_TF_WhitePaper_AccessControl_2009-09-28.pdf).

Access control constraints may result in data returned in a read or search being redacted or otherwise restricted. See [Variations between Submitted data and Retrieved data \(updates.html\)](#).

6.1.0.5.1 Access Control Considerations

The FHIR RESTful API provides several ways that a client may request or create information. When designing a system to authorize access to information, all potential access methods must be considered. They include the following:

- The basic CRUD methods on resources. A security implementation must evaluate whether a client can read, update create or delete a given resource.
- Chained search provides the ability to disclose information on related resources. A security implementation must consider whether a client has the permission to access the resource being searched on, as well as the chained resource(s)
- `_include` and `_revinclude` search parameters allow client to request related resources. A security implementation must determine if the client has access to the included resources.
- [security labels \(security-labels.html\)](#).
- Several resources, including Bundle, Composition, Group and List, are designed to contain other resources. A security implementation should consider whether access to an individual resource, such as a Bundle, should permit access to all resources contained within the resource.
- FHIR defines several operations that may be supported by a server. Security implementations must evaluate whether a client can invoke these operations and what information should be returned from them. Fetch Encounter Record, Evaluate Measure, Observation Statistics, Find Patient Matches using MPI-based Logic, and Fetch Patient Record specifically provide the ability to disclose patient information.
- Batch and transaction processing provide ways for clients to create and update information in bulk. Security implementations should consider whether a client can initiate one of these interactions and make authorization decisions on each action in the batch/transaction.
- Security implementations must be aware of the [Break the Glass protocol \(security-labels.html#break-the-glass\)](#) (e.g. break the glass) ([example \(operationoutcome-example-break-the-glass.html\)](#)).

6.1.0.5.2 Access Denied Response Handling

A web-server, especially hosting FHIR, must choose the response carefully when an Access Denied condition exists. Returning too much information may expose details that should not be communicated. The Access Denied condition might be because of missing but required Authentication, the user is not authorized to access the endpoint, the user is not authorized to access specific data, or other policy reasons.

To balance usability of the returned result vs appropriate protection, the actual result method used needs to be controlled by policy and context. Typical methods of handling Access Denied used are:

Return a Success with Bundle containing zero results - This result is indistinguishable from the case where no data is known. When consistently returned on Access Denied, this will not expose which patients exist, or what data might be blinded. This method is also consistent with cases where some results are authorized while other results are blinded. This can only be used when returning a Bundle is a valid result.

Return a 404 "Not Found" - This also protects from data leakage as it is indistinguishable from a query against a resource that doesn't exist. It does however leak that the user authentication is validated.

Return a 403 "Forbidden" - This communicates that the reason for the failure is an Authorization failure. It should only be used when the client and/or user is well enough known to be given this information. Thus this method is most used when the user can know that they are forbidden access. It doesn't explain how the user might change things to become authorized.

Return a 401 "Unauthorized" - This communicates that user authentication was attempted and failed to be authenticated.

Note that if a server allows PUT to a new location (<http.html#upsert>), it is not feasible to return 404 Not Found. This means that clients can use this to test whether content exists that they are not able to access, which is a minor, but potentially significant, leak of information.

6.1.0.6 Audit Logging

FHIR provides an [AuditEvent](#) ([auditevent.html](#)) resource suitable for use by FHIR clients and servers to record when a security or privacy relevant event has occurred. This form of audit logging records as much detail as reasonable at the time the event happened.

When used to record security and privacy relevant events, the AuditEvent can then be used by properly authorized applications to support audit reporting, alerting, filtering, and forwarding. This model has been developed and used in healthcare for a decade as [IHE-ATNA profile](#) [ⓘ](http://wiki.ihe.net/index.php?title=Audit_Trail_and_Node_Authentication) (http://wiki.ihe.net/index.php?title=Audit_Trail_and_Node_Authentication). ATNA log events can be automatically converted to AuditEvent resources, and from there, client applications are able to search the audit events, or subscribe to them.

For HTTP logs, implementers need to consider the implications of distributing access to the logs. HTTP logs, including those that only contain the URL itself, should be regarded as being as sensitive as the resources themselves. Even if direct PHI is kept out of the logs by careful avoidance of search parameters (e.g. by using POST), the logs will still contain a rich set of information about the clinical records.

6.1.0.7 Attachments

Several FHIR resources include attachments. Attachments can either be references to content found elsewhere or included inline encoded in base64. Attachments represent security risks in a way that FHIR resources do not, since some attachments contain executable code. Implementers should always use caution when handling resources.

6.1.0.8 Security Labels

See [Security Labels](#) ([security-labels.html](#)).

6.1.0.9 Narrative

FHIR resources include an XHTML narrative, so that applications can display the contents of the resource to users without having to fully and correctly process the data in the resource. However, displaying HTML is associated with several known security issues that have been observed in production systems in other contexts (e.g. [with CDA](#) [ⓘ](http://smartplatforms.org/2014/04/security-vulnerabilities-in-ccda-display/) (<http://smartplatforms.org/2014/04/security-vulnerabilities-in-ccda-display/>)). For this reason, the [FHIR narrative can't contain active content](#) ([narrative.html#security](#)). However, care is still needed when displaying the narrative:

- Validate the narrative (the standard FHIR schemas do not allow active content, and the reference implementations won't handle it). Note, though, that external references could still be included in CSS, and removing/preventing these are outside the scope of schemas and reference implementations.
- Ensure that any external references to images or anchors (e.g. outside the resource) do not cause the display software to [leak sensitive information in headers](#) [ⓘ](http://smartplatforms.org/2014/04/security-vulnerabilities-in-ccda-display/) (<http://smartplatforms.org/2014/04/security-vulnerabilities-in-ccda-display/>).
- Do not allow external links to run in a privileged context such as the EHR unless you are sure they can be trusted
- Care should be taken to differentiate HTTP RESTful (API) from browser-based server content. Specifically, one should separate user session cookies, as an attacker could create content that serves up with content-type "text/html" and has content like "`<script>send_to_attacker(document.cookie);</script>`".

Also note that the inclusion of an external reference to an image can allow the server that hosts the image to track when the resource is displayed. This may be a feature or a problem depending on the context.

In addition to narrative, [Documents](#) ([documents.html](#)) may also contain stylesheets. Unlike with CDA, the stylesheets are simple CSS stylesheets, not executable XSLT, so the same security risks do not apply. However, CSS stylesheets may still reference external content (e.g. background images), and applications displaying documents should ensure that CSS links are not automatically followed without checking their safety first, and that session/identifying information does not leak with any use of external links.

© HL7.org 2011+. FHIR Release 4 (Technical Correction #1) (v4.0.1) generated on Fri, Nov 1, 2019 09:37+1100. [QA Page \(qa.html\)](#).

Links: [Search](#) (<http://hl7.org/fhir/search.cfm>) | [Version History \(history.html\)](#) | [Table of Contents \(toc.html\)](#) | [Credits \(credits.html\)](#) | [Compare to R3](#) (<https://www.fhir.org/perl/htmldiff.pl?oldfile=http%3A%2F%2Fhl7.org%2Ffhir%2FSTU3%2Fsecurity.html&newfile=http%3A%2F%2Fhl7.org%2Ffhir%2FR4%2Fsecurity.html>) |  ([license.html](#)) | [Propose a change](#) (<http://hl7.org/fhir-issues>).